Category:

Network

Name:

Relayed and Betrayed

Message:

An attack suspected to be an inside job has been detected on the machine at 192.168.56.104 within the corporate network. According to the incident investigation, there is a possibility that authentication credentials were leaked from the machine at 192.168.56.33. Your mission is to analyze the provided packet data, identify the attack method used, uncover the potentially leaked credentials, and expose the traitor within the organization.

Extraction password is "csg2025".

To proof your understanding, please create flag by

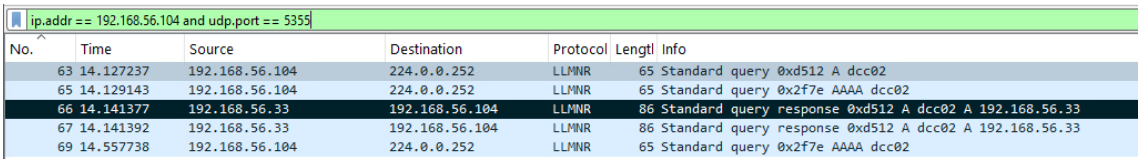
"**CSG_FLAG{bob::windomain:46f422cd882b169d:4837e8d20080f19cc2762798c9373a8e:0101000000000000934f159ee807dc01c70a33e89710d31400000000020012005700490040044004f004d00410049004e0001000e00570049004e00310030002d00320004001e00770069006e0064006f006d00610069006e002e006c006f00630061006c0003002e00770069006e00310030002d0032002e00770069006e0064006f006d00610069006e002e006c006f00630061006c0005001e00770069006e0064006f006d00610069006e002e006c006f00630061006c0007000800934f159ee807dc010600040002000000080030003000000000000000000000000200000d680c970ffd7be19f29a3b7d61c7d3353ee63fdfa4fd83344a83f7681a6b65980a0010000000000000000000000000000000000000000900140063006900660073002f006400630063003000320000000000000000}**"

Instructions:

1. The packet of interest in this case uses the LLMNR protocol. LLMNR (Link-Local Multicast Name Resolution) is used in Windows environments for name resolution within a local network, particularly when DNS fails to resolve a hostname. When a host cannot resolve a name via DNS, it sends a request to the multicast address 224.0.0.252, asking if any other host on the network can resolve the name.

   In this instance, the host at 192.168.56.33 attempted to resolve the hostname "dcc02" using LLMNR. This suggests that the hostname "dcc02" may have been entered incorrectly on that host. Additionally, after 192.168.56.33 broadcasted the request, a response was received from

192.168.56.104.



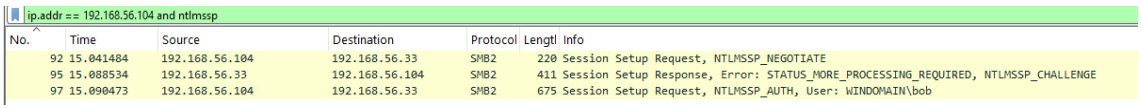
ip.addr == 192.168.56.104 and udp.port == 5355

No.	Time	Source	Destination	Protocol	Lengtl	Info
63	14.127237	192.168.56.104	224.0.0.252	LLMNR	65	Standard query 0xd512 A dcc02
65	14.129143	192.168.56.104	224.0.0.252	LLMNR	65	Standard query 0x2f7e AAAA dcc02
66	14.141377	192.168.56.33	192.168.56.104	LLMNR	86	Standard query response 0xd512 A dcc02 A 192.168.56.33
67	14.141392	192.168.56.33	192.168.56.104	LLMNR	86	Standard query response 0xd512 A dcc02 A 192.168.56.33
69	14.557738	192.168.56.104	224.0.0.252	LLMNR	65	Standard query 0x2f7e AAAA dcc02

2. When an incorrect hostname is entered, a broadcast using the LLMNR protocol is triggered. In this case, the response came from the machine at 192.168.56.104, which may have been compromised. Based on this behavior, it is likely that the attack method used was LLMNR poisoning.
3. An attacker can use tools such as Responder or Inveigh on a compromised machine to listen for LLMNR requests and capture NTLMv2 hashes from unsuspecting users. In other words, based on the packet data in this pcap file, it may be possible to identify the leaked NTLMv2 hash.
4. The NTLMv2 hash follows the format shown below.

   username::domainname:ServerChallenge:NTProofStr:NTLMv2Response

   Therefore, if the following four pieces of information sent from 192.168.56.104 to 192.168.56.33 can be identified in the packet data, it may be possible to determine the credentials of the user whose information was leaked.
5. To identify the leaked NTLMv2 hash, filter the packet capture to include only those packets related to NTLM authentication.



ip.addr == 192.168.56.104 and ntlmssp

No.	Time	Source	Destination	Protocol	Lengtl	Info
92	15.041484	192.168.56.104	192.168.56.33	SMB2	220	Session Setup Request, NTLMSSP_NEGOTIATE
95	15.088534	192.168.56.33	192.168.56.104	SMB2	411	Session Setup Response, Error: STATUS_MORE_PROCESSING_REQUIRED, NTLMSSP_CHALLENGE
97	15.090473	192.168.56.104	192.168.56.33	SMB2	675	Session Setup Request, NTLMSSP_AUTH, User: WINDOMAIN\bob

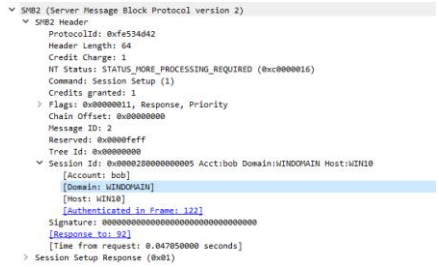
6. To construct the NTLMv2 hash, extract the following information from the packet data.

   username: NTLMSSP_CHALLENGE > SMB2 (Server Message Block Protocol version 2) > SMB2 Header > Session Id > Account

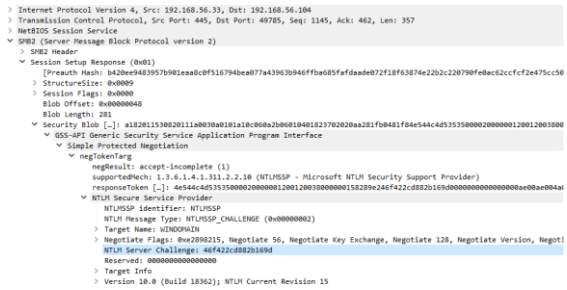


```
SMB2 (Server Message Block Protocol version 2)
  SMB2 Header
      ProtocolId: 0xfe534d42
      Header Length: 64
      Credit Charge: 1
      NT Status: STATUS_MORE_PROCESSING_REQUIRED (0xc0000016)
      Command: Session Setup (1)
      Credits granted: 1
    > Flags: 0x00000011, Response, Priority
      Chain Offset: 0x00000000
      Message ID: 2
      Reserved: 0x0000feff
      Tree Id: 0x00000000
    v Session Id: 0x0000280000000005 Acct:bob Domain:WINDOMAIN Host:WIN10
        [Account: bob]
        [Domain: WINDOMAIN]
        [Host: WIN10]
        [Authenticated in Frame: 122]
      Signature: 00000000000000000000000000000000
      [Response to: 92]
      [Time from request: 0.047050000 seconds]
  > Session Setup Response (0x01)
```

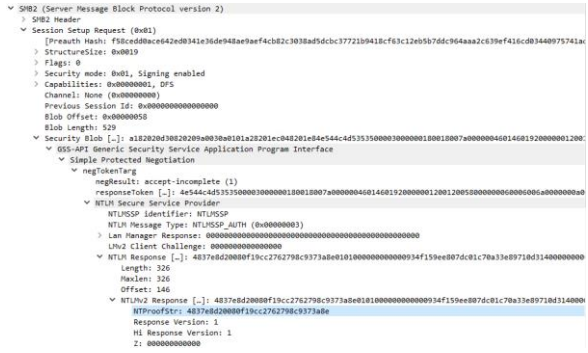
   domainname: NTLMSSP_CHALLENGE > SMB2 (Server Message Block Protocol version 2) > SMB2 Header > Session Id > Account



ServerChallenge: NTLMSSP_CHALLENGE > SMB2 (Server Message Block Protocol version 2) > Session Setup Response (0x01) > Security Blob > GSS-API Generic Security Service Application Program Interface > Simple Protected Negotiation > negTokenTarg > NTLM Secure Service Provider > NTLM Server Challenge



NTProofStr: NTLMSSP_AUTH > SMB2 (Server Message Block Protocol version 2) > Session Setup Request (0x01) > Security Blob > GSS-API Generic Security Service Application Program Interface > Simple Protected Negotiation > negTokenTarg > NTLM Secure Service Provider > NTLM Response > NTLMv2 Response > NTProofStr



NTLMv2Response: NTLMSSP_AUTH > SMB2 (Server Message Block Protocol version 2) > Session Setup Request (0x01) > Security Blob > GSS-API Generic Security Service Application Program Interface > Simple Protected Negotiation > negTokenTarg > NTLM Secure Service Provider > NTLM Response > NTLMv2 Response



7. The extracted information can be summarized as follows:

   username: bob

   domainname: WINDOMAIN

   ServerChallenge: 46f422cd882b169d

   NTProofStr: 4837e8d20080f19cc2762798c9373a8e

   NTLMv2Response:

   4837e8d20080f19cc2762798c9373a8e0101000000000000934f159ee807dc01c70a33e89710d3140000000002001200570049004e0044004f004d00410049004e0001000e00570049004e00310030002d00320004001e00770069006e0064006f006d00610069006e002e006c006f00630061006c0003002e00770069006e00310030002d0032002e00770069006e0064006f006d00610069006e002e006c006f00630061006c0005001e00770069006e0064006f006d00610069006e002e006c006f00630061006c0007000800934f159ee807dc010600040002000000080030003000000000000000000000000200000d680c970ffd7be19f29a3b7d61c7d3353ee63fdfa4fd83344a83f7681a6b65980a0010000000000000000000000000000000000000900140063006900660073002f006400630063003000320000000000000000000

   *** The value with the first 32 characters, which duplicate NTProofStr, removed.**

   The flag is a combination of the above elements formatted according to the NTLMv2 structure.

*** Do not forget to include the colons.**

Flag is:

CSG_FLAG{bob::windomain:46f422cd882b169d:4837e8d20080f19cc2762798c9373a8e:0101000000000000934f159ee807dc01c70a33e89710d3140000000002001200570049004e0044004f004d00410049004e0001000e00570049004e00310030002d00320004001e00770069006e0064006f006d00610069006e002e006c006f00630061006c0003002e00770069006e00310030002d0032002e00770069006e0064006f006d00610069006e002e006c006f00630061006c0005001e00770069006e00640

06f006d00610069006e002e006c006f00630061006c0007000800934f159ee807dc01060004000200
0000080030003000000000000000000000000000200000d680c970ffd7be19f29a3b7d61c7d3353ee63
fdfa4fd83344a83f7681a6b65980a001000000000000000000000000000000000000009001400630069
00660073002f00640063006300300032000000000000000000}